



A Critical Analysis and Extension of
"How does Endpoint Detection use the MITRE ATT&CK Framework?"

(Virkud, Inam, Riddle, Liu, Wang, & Bates, USENIX Security 2024)

Extending Coverage Analysis with Microsoft Sentinel:
A Fifth-Ruleset Test of Architectural Asymmetry in ATT&CK Coverage

INFO 5001: Security Principles

Research Project

Master of Information Technology (Computing and Innovation)

Adelaide University

Junaid Abrar Razeen

Student ID: a1991907

Course Coordinator: Dr. Md Mokammel Haque

June 2026

Executive Summary

This report critically analyses Virkud et al.'s 2024 USENIX Security paper "How does Endpoint Detection use the MITRE ATT&CK Framework?", evaluates the publicly-released artefact for reproducibility, reproduces the paper's main quantitative and qualitative findings, and extends the analysis with a fifth ruleset that the original work omitted: Microsoft Sentinel. The work positions itself within the foundational frameworks taught in INFO 5001 (MITRE ATT&CK, the Unified Kill Chain, cyber threat intelligence, defence-in-depth, and ISO 27001) and frames the paper's critique of ATT&CK-as-security-metric in terms of those frameworks.

The forensic analysis identifies twelve substantive strengths and seventeen substantive weaknesses in the paper, with several weaknesses derived from course-anchored frameworks (the Unified Kill Chain, the ACSC Essential Eight, ISO 27001's checkbox-compliance failure mode) that the original authors did not invoke. The artefact evaluation walks through twenty-seven documented reproduction events, including five distinct version-drift workarounds (NumPy 2.0, pandas 3.0, Linux-only CUDA dependencies, NLTK 3.9 tokenizer rename, and a circular import in the artefact's Jupyter notebook structure) that were resolved without dropping back to the original Python 3.8.10 environment. All headline findings of the paper (coverage by tactic, technique-density distributions, Spearman rank correlations, and the four qualitative case studies on labelling inconsistency) were reproduced and match the paper's reported values to three decimal places.

The improvement extends the analysis by adding Microsoft Sentinel as a fifth ruleset, applying the same filtering methodology the original authors used for Splunk and Elastic. Sentinel is the largest cloud-native SIEM by deployment share, was publicly available at the time of Virkud et al.'s data collection, and is conspicuously absent from the original paper. Adding Sentinel surfaces three converging findings:

1. Sentinel covers 41.4% of ATT&CK v11, below but adjacent to the commercial range Virkud et al. report (48–55%), extending the range to "41–55%" when cloud-native SIEMs are included.
2. A pre-registered hypothesis that Sentinel would over-cover cloud and identity techniques and under-cover host-only techniques is strongly confirmed: Sentinel has 2–6 times more rules for T1078 (Valid Accounts), T1098 (Account Manipulation), and T1110 (Brute Force / Password Spraying) than the on-host EDR products, but 5–26 times fewer rules for T1547 (Boot or Logon Autostart), T1543 (Create or Modify System Process), and T1055 (Process Injection).
3. Spearman rank correlations between Sentinel and each of Virkud et al.'s rulesets fall in the range $p = 0.39$ – 0.50 (all $p < 0.001$), substantially below the within-paper range of $p = 0.64$ – 0.76 . The drop in rank correlation quantifies what the hypothesis test shows qualitatively: Sentinel does not just have different volumes of rules per technique; it has a structurally different ordering of which techniques it prioritises.

Taken together, these findings add a third failure mode to Virkud et al.'s critique of ATT&CK-as-security-metric. The original paper argues the metric fails because (a) the headline coverage figure is inflated by low-severity rules, and (b) different vendors apply different ATT&CK labels to the same threats. This report demonstrates a third failure mode: (c) ATT&CK coverage is partly an artefact of telemetry architecture, not just detection effort. A cloud-native SIEM and an on-host EDR cannot meaningfully be compared on technique coverage because they have access to fundamentally different log sources. The implication for security procurement, cyber insurance, and the threat-informed defence movement is that ATT&CK coverage scores are not commensurable across architectural categories, and any comparative use of the metric requires explicit normalisation by data source.

The artefact-evaluation phase achieved cross-platform reproduction on Windows 11 with Python 3.11.9, a deviation from the artefact authors' Linux / Python 3.8.10 environment that we adopted deliberately to surface and document the dependency drift that arises when reproducing security-research artefacts more than 18 months after publication. We argue this deviation is itself a secondary contribution of the present work: it produces a record of the workarounds required for non-Linux researchers attempting to reproduce the artefact, which is information the original supplementary materials do not provide.

1. Introduction

1.1 The MITRE ATT&CK Framework as Industry Currency

The MITRE ATT&CK framework was introduced in 2013 to describe and categorise adversarial behaviours based on real-world observations, organising them into a matrix of fourteen tactics representing the "why" of an attack and 191 (in Version 11) techniques representing the "how". The framework was developed to enable threat-informed defence, the practice of aligning defensive capability investment with the techniques observed in actual attacker behaviour. In the decade since its introduction, ATT&CK has been adopted by endpoint detection and response (EDR) vendors, Security Information and Event Management (SIEM) platforms, cyber threat intelligence (CTI) feeds, the cyber insurance industry, and most recently by procurement frameworks that use ATT&CK technique coverage as a security-posture metric.

This adoption has produced an emerging industry currency. Detection vendors advertise the percentage of ATT&CK techniques their product covers; cyber insurers reference ATT&CK coverage in underwriting; and security teams use ATT&CK Navigator overlays to justify capability gaps to executive leadership. The implicit assumption is that ATT&CK coverage is a comparable, commensurable measurement that meaningfully reflects an organisation's ability to detect adversarial behaviour.

Virkud et al. challenge that assumption. Their 2024 USENIX Security paper conducts the first systematic empirical analysis of how four widely-deployed endpoint detection rulesets (Carbon Black, Splunk, Elastic, and the crowdsourced Sigma project) use the MITRE ATT&CK framework. By examining 4,446 ATT&CK-tagged rules across these rulesets in a snapshot taken October 2022, they demonstrate that ATT&CK technique coverage as a security metric is inflated, structurally bounded, and inconsistent across vendors.

1.2 Course Context

The MITRE ATT&CK framework is introduced in Module 1, Topic 3 of INFO 5001 as part of the unit's coverage of cybersecurity attack lifecycles and motivations. The course presents ATT&CK alongside Lockheed Martin's Cyber Kill Chain and the Unified Kill Chain (Pols, 2021), framing it as a knowledge base of adversary tactics and techniques where "tactics represent the why" and "techniques represent how an adversary achieves a tactical objective." Threat-based defence is described in the course materials as the practice of mapping an organisation's "defensive tools and capabilities across the cyber attack lifecycle, [revealing] opportunity gaps as investment needs."

Endpoint detection sits inside the defence-in-depth model taught in Module 3, Topic 9, where it is presented as one layer of a multi-layer defensive strategy alongside perimeter security, network segmentation, monitoring and incident response, and user education. The course materials explicitly flag a limitation of endpoint-focused security: "Device Dependency: If the device is compromised, its own security may be bypassed." This caveat is directly relevant to the present analysis, because Virkud et al.'s entire scope is endpoint detection: they evaluate the rulesets of EDR and SIEM products that ingest endpoint telemetry. Any conclusions about ATT&CK coverage in their paper are bounded by that architectural constraint.

The Module 2 Topic 4 case study on the 2023–2024 Microsoft cyberattack by the Nobelium / Midnight Blizzard threat group provides a concrete real-world example that intersects directly with Virkud et al.'s analysis. Nobelium is one of nine "malicious entities" the paper identifies as being explicitly detected by all three commercial products in its Figure 6. The attack employed password spraying (T1110.003) and

valid-account abuse (T1078) to compromise legacy non-production tenant accounts at Microsoft, both techniques that the present report's Sentinel extension will show are heavily over-represented in Microsoft's own SIEM ruleset and under-represented in the on-host EDR products in the original paper.

1.3 Scope and Contributions of This Report

The report contributes the following to the existing literature on ATT&CK as a security metric:

- A critical analysis of Virkud et al.'s paper structured around the cyber threat intelligence layers introduced in Module 2 (tactical, operational, strategic), identifying twelve substantive strengths and seventeen substantive weaknesses, with course-anchored framing where relevant.
- A complete reproduction of the paper's main findings (RQ1 coverage analyses and RQ3 case studies of labelling inconsistency) on a Windows / Python 3.11 environment that differs from the artefact authors' Linux / Python 3.8 environment. Twenty-seven distinct reproduction events are documented, including five major version-drift workarounds.
- A novel extension that adds Microsoft Sentinel as a fifth ruleset to the original four. Sentinel is the largest cloud-native SIEM by deployment share, was publicly available at the time of the paper's data collection, and is conspicuously absent from the original work.
- A pre-registered hypothesis test confirming that Sentinel over-covers cloud and identity techniques (T1078, T1098, T1110) and under-covers host-only techniques (T1547, T1543, T1574, T1055) compared to the on-host EDR products in the original paper.
- A novel Spearman rank correlation analysis quantifying the technique-priority divergence between Sentinel and the original four rulesets ($\rho = 0.39\text{--}0.50$, all $p < 0.001$), substantially below the within-paper range of $\rho = 0.64\text{--}0.76$.
- An interpretive contribution that adds a third failure mode to Virkud et al.'s critique of ATT&CK-as-security-metric: ATT&CK coverage is partly an artefact of telemetry architecture, not just detection effort, and is therefore not commensurable across architectural categories.

1.4 Report Structure

Section 2 provides a four-sentence summary of the paper as required by the assignment rubric. Section 3 conducts the critical analysis, structured around the CTI tactical/operational/strategic framework. Section 4 evaluates the artefact across the five rubric criteria (Documented, Consistent, Complete, Exercisable, Results Reproduced) with reference to the twenty-seven-entry reproduction log. Section 5 presents the Microsoft Sentinel extension, including methodology, implementation, and the three converging findings. Section 6 discusses implications for ATT&CK-as-security-metric and connects them back to course frameworks. Section 7 concludes and identifies directions for future work.

2. Paper Summary

Virkud et al. conduct the first systematic empirical analysis of how four widely-deployed endpoint detection rulesets (Carbon Black, Splunk, Elastic, and the crowdsourced Sigma) use the MITRE ATT&CK framework, asking whether ATT&CK technique coverage is a sound metric of security posture. Using an October 2022 snapshot of 867 / 911 / 473 / 2,195 ATT&CK-tagged rules respectively (4,446 rules in total), they find that commercial coverage sits at 48–55% but collapses to 25–26% once low-risk and low-severity rules are filtered out; that 53 ATT&CK techniques (27.7%) are unimplemented by any commercial product for characterisable structural reasons (off-host targets, provenance requirements, hardware-level techniques, human-factor techniques); and that products targeting the same 37 malicious entities agree on only 12.5% of their ATT&CK technique annotations. The paper concludes that ATT&CK technique coverage, as marketed by vendors and increasingly used in cyber insurance and procurement, is an inflated, structurally-bounded, and inconsistent measure of security efficacy. Note that the paper analyses signature-based detection rulesets exclusively, one of the three IDS/IPS detection methodologies introduced in Module 1, Topic 1 (alongside anomaly-based detection and stateful protocol analysis); the conclusions therefore do not generalise to behavioural or anomaly-based detection products.

3. Critical Analysis

This section organises the strengths and weaknesses of Virkud et al. around the three-layer cyber threat intelligence framework introduced in Module 2, Topic 4 of INFO 5001: tactical CTI (the specific tools, techniques, and procedures attackers use), operational CTI (specific upcoming threats or ongoing campaigns), and strategic CTI (long-term trends and high-level positioning). Each strength and weakness is tagged with the CTI layer it speaks to, and course-anchored connections are flagged where present.

3.1 Strengths

The paper has twelve substantive strengths, ranked here roughly by likely contribution to the overall argument.

S1. Novelty and timeliness (Strategic)

The paper presents the first systematic empirical analysis of how EDR / SIEM products use the MITRE ATT&CK framework. Prior work measured individual products' detection performance (Karantzas and Patsakis 2021 on EDR efficacy) or how researchers use ATT&CK in academic publications (Roy et al. 2023), but no prior work quantified vendor coverage and inter-vendor labelling consistency at the ruleset level. The paper enters a measurement gap that the security industry was already filling with marketing claims and procurement decisions, which makes its critique timely and operationally consequential.

S2. Multi-product breadth yields generalisability (Tactical)

Including three major commercial products (each at or near the top of Gartner and Forrester rankings in their respective categories) plus a large crowdsourced ruleset gives the analysis breadth that single-product studies lack. The combined dataset of 4,446 ATT&CK-tagged rules cannot be attributed to any single vendor's idiosyncrasies. The Sigma replication in Appendix A serves as a robustness check, and the same trends hold across all four rulesets, strengthening the claim that the observed patterns are properties of ATT&CK-as-metric rather than artefacts of vendor-specific decisions.

S3. Three-pronged methodology answers three distinct research questions (Strategic)

The paper organises its analysis around three research questions: how do products use ATT&CK (RQ1, quantitative coverage analysis); why don't products implement all of ATT&CK (RQ2, qualitative open coding of unimplemented techniques); and how consistently is ATT&CK applied across products (RQ3, cross-product labelling consistency analysis). Each research question addresses a distinct failure mode of ATT&CK-as-metric, and the combination is stronger than any single methodology would have been. Each layer surfaces findings the others miss: RQ1 quantifies coverage breadth, RQ2 explains structural ceilings on coverage, and RQ3 demonstrates that even when products do cover the same threat they disagree about what they are covering.

S4. Operationally meaningful finding on risk/severity filtering (Tactical)

The finding that ATT&CK coverage drops from 48–55% to 25–26% when only high-risk and high-severity rules are retained is directly actionable for security operations teams who triage alerts by severity. This converts an abstract debate about whether coverage is "meaningful" into a concrete operational claim: roughly half of the marketed coverage figure comes from rules that SOC analysts would deprioritise in practice. This finding connects directly to the SIEM-driven Monitoring and Incident Response capability

described in Module 3, Topic 9 of INFO 5001, where the value of a rule is determined not by its existence but by whether it produces alerts that analysts can act on.

S5. Statistical rigour in coverage-similarity analysis (Tactical)

Spearman rank correlations between pairs of products ($\rho = 0.634$ for Carbon Black–Splunk, 0.639 for Splunk–Elastic, 0.744 for Carbon Black–Elastic, and figures for pairs involving Sigma in the range 0.701–0.793, all $p < 0.001$) provide a defensible quantitative basis for the paper's claim that vendors share similar preferences for which techniques to cover. This is methodologically stronger than visual inspection of bar charts and gives the within-paper analyses inferential power that downstream researchers can build on, as the present report does in Section 5.

S6. Conservative open-coding methodology for unimplemented techniques (Strategic)

The qualitative analysis in Section 5 of the paper uses three independent coders with iterative codebook refinement and conservative classification rules, for example, the code "ineffective detection method" is only applied when MITRE itself flags the technique as hard to detect, rather than when the coders subjectively believe so. The resulting taxonomy of ten reasons for non-implementation is reusable by other researchers and is grounded in MITRE's own technique descriptions rather than coder opinion. This is a methodological transparency strength.

S7. The "unrealizable technique" insight is conceptually important (Strategic)

Establishing that some ATT&CK techniques are inherently hard to detect on endpoints (because they target third parties, require provenance graphs, occur at the hardware or firmware level, exploit removable media, or rely on human-factor manipulation) reframes the entire coverage-as-security debate. 100% coverage is not just unattainable in practice; it is not meaningful as a goal. This insight connects to the endpoint-security limitations discussed in Module 3, Topic 9 (specifically, "Device Dependency: If the device is compromised, its own security may be bypassed"): the paper's "unrealizable" category is the structural counterpart of the course's "device dependency" caveat, showing that even when endpoint detection works, the framework being measured against is partly out of reach.

S8. The consistency analysis is the most damaging finding for ATT&CK-as-metric (Operational)

The finding that vendors targeting the same threat (for example FIN7, SUNBURST, Nobelium, Ryuk, Trickbot) agree on only 12.5% of ATT&CK technique annotations is a clean falsification of the implicit assumption underpinning ATT&CK-based product comparison. The CVE-2021-4034 case study in Section 6 of the paper is particularly compelling: Carbon Black tags the vulnerability under T1548, while Elastic and Splunk tag it under T1068. Both labels are defensible (privilege escalation can be characterised as either Abuse Elevation Control Mechanism or Exploitation for Privilege Escalation), which is precisely what makes the result damaging. The disagreement is not sloppy work; it is two equally-valid readings of the same threat, which means ATT&CK technique coverage cannot be used as a basis for product comparison even when products demonstrably address the same threats. This finding also intersects with Module 2's teaching on the Nobelium / Midnight Blizzard case study, since Nobelium is among the threats with explicit dedicated rules in all three commercial products and is among those for which vendors disagree on technique labels.

S9. Clear ATT&CK-version transparency (Tactical)

The paper explicitly fixes the analysis to ATT&CK Version 11 (191 techniques, 14 tactics, October 2022). This is good measurement hygiene: coverage numbers can only be interpreted against a fixed denominator, and pinning the version allows other researchers to reproduce the analysis or extend it to a different version while comparing like with like. The present report's Sentinel extension benefits directly from this transparency, since the Sentinel CSV we use also references ATT&CK v11 mappings, allowing direct comparison.

S10. Open artefact and dataset (Tactical)

The supplementary materials on GitHub (github.com/avirkud/endpoint-detection-mitreattack) include the rule dataset, ATT&CK technique mappings, and Jupyter notebooks reproducing the figures. The artefact received the USENIX Security 2024 Artifact Evaluation "Available", "Functional", and "Reproduced" badges, indicating it passed independent evaluation. This is a substantive strength because much security research is not reproducible at all; Virkud et al. are among the minority of security publications that ship the data and code needed for independent reproduction.

S11. Methodological humility (Strategic)

The paper repeatedly clarifies what it does not claim. The authors are careful to note that they evaluate ATT&CK as a metric, not the products themselves, and that low overlap in dedicated rules does not mean low security; generic rules may catch a threat even when no rule explicitly mentions it. This humility blunts predictable vendor pushback and strengthens the surviving conclusions. The framing parallels the course's treatment of ISO 27001 in Module 3, Topic 10, where the textbook similarly cautions that compliance frameworks "provide structure" but are "only as effective as the effort put into [them]", both texts argue that the framework is a tool for organising security work, not a substitute for it.

S12. Practical, multi-audience recommendations (Strategic)

Section 8.2 of the paper gives concrete recommendations for vendors (drop the conflation between "techniques" and "tactics-techniques-procedures"), for MITRE itself (include risk and severity metadata in the framework), for practitioners (prefer D3FEND and NIST CSF for defensive capability evaluation), and for cyber insurers (do not use ATT&CK coverage as a primary metric). The multi-audience targeting is good policy framing, and the specific alternatives (D3FEND, NIST CSF) are recognised in the security frameworks coverage of Module 3, Topic 10, where the course presents ISO 27001 alongside NIST as established compliance frameworks.

3.2 Weaknesses

The paper has seventeen substantive weaknesses, several of which are addressed directly by the Microsoft Sentinel extension presented in Section 5 of this report. Weaknesses tagged "[course]" are grounded in frameworks taught in INFO 5001; weaknesses tagged "[addressed]" are partially or fully resolved by the extension.

W1. Snapshot-in-time analysis with no estimate of finding half-life (Tactical) [addressed]

The dataset was captured in October 2022 against ATT&CK Version 11. ATT&CK has since advanced through several major versions, rulesets are continuously updated, and individual technique annotations evolve as vendors refactor their detection content. The paper does not estimate the rate of drift, so a reader cannot tell whether the 48–55% figure is stable, growing, or shrinking. The present report's Sentinel extension partially addresses this by demonstrating that the public Microsoft Sentinel feed is itself frozen at August 2022 (within two months of Virkud et al.'s October 2022 snapshot), allowing direct temporal comparison rather than time-shifted analysis.

W2. Notable absence of Microsoft Sentinel and CrowdStrike Falcon (Tactical) [addressed]

The authors note that they are not aware of any other public or semi-public commercial rulesets to include, but Microsoft maintains a public ATT&CK-tagged ruleset for Sentinel at github.com/microsoft/mstic/PublicFeeds/MITREATT%26CK/MicrosoftSentinel.csv, with thousands of additional rules available in the github.com/Azure/Azure-Sentinel repository. Microsoft Sentinel is consistently at the top of Gartner Magic Quadrant ratings for SIEM, and was publicly available at the time of the paper's data collection. This is a substantive omission, not merely a representativeness limitation. The omission is particularly consequential given that Nobelium / Midnight Blizzard, one of the malicious entities the paper studies in its consistency analysis, is precisely the attacker profile Microsoft Sentinel is built to detect. Section 5 of this report addresses W2 directly by adding Sentinel as a fifth ruleset and reporting how it changes the picture.

W3. Coverage treats all rules as equal in informational weight (Tactical)

A single Splunk rule covering T1059 (Command and Scripting Interpreter) contributes the same to the "coverage" calculation as Carbon Black's 142 rules for T1218 (Signed Binary Proxy Execution). The paper acknowledges density variation in Figure 2 but the headline coverage figure does not reflect detection robustness: a technique with one fragile, narrow rule is "covered" by the same definition as a technique with 142 well-tested, broad rules. This conflates breadth with depth and makes the coverage number harder to interpret as a security signal. The course's framing of defence-in-depth (Module 3, Topic 9) emphasises that depth and redundancy of detection matter more than narrow checkpoints, which suggests rule density should be weighted more heavily in any "coverage" metric.

W4. No ground-truth validation of vendor ATT&CK tagging (Operational)

The paper accepts vendor-supplied ATT&CK labels at face value throughout. There is no check that a rule tagged with T1059 actually detects T1059 behaviour, or that the technique annotation is appropriate to the rule's detection logic. The consistency analysis in Section 6 surfaces some of this issue indirectly: different vendors disagree, so at most one (and possibly none) is correct, but the paper never asks: when vendors do agree, are they correct? Vendor incentives to over-tag rules with high-profile techniques for marketing purposes could systematically inflate the coverage figure, and the paper has no mechanism to detect this.

W5. Sigma is not architecturally comparable to the three commercial rulesets (Tactical)

Sigma is a vendor-agnostic, community-maintained format with thousands of contributors and no commercial quality-assurance process. Its 79% ATT&CK coverage and statistically similar rank correlations are reported in parallel with commercial figures, and although the paper appropriately segregates Sigma into Appendix A, a casual reader may conflate Sigma's higher coverage with what a commercial ruleset could achieve. The Sigma comparison is informative but is treated as if it answers the same question the commercial comparison answers, when in fact it answers a different question (what coverage looks like when crowdsourced rather than commercially curated).

W6. No inter-rater reliability for qualitative coding (Operational)

The paper explicitly states: "Since all technique codes are collaboratively reviewed by multiple researchers, we do not report inter-rater reliability." This is methodologically weak: consensus after discussion is not the same as independent agreement, and standard reporting practice for qualitative coding in security research is to provide Cohen's κ or Krippendorff's α on the independent first round. The absence of such a statistic in Virkud et al. is a missing transparency step.

W7. The "ineffective detection method" code is a circular indicator (Strategic)

The paper applies the code "ineffective detection method" (its largest single category, accounting for 39.6% of unimplemented techniques) only when MITRE itself flags the technique as hard to detect in the technique description. This means the most common reason for non-implementation, by the paper's own accounting, is essentially "MITRE flagged this technique as hard." The paper does not separately measure whether vendors agree with MITRE's self-assessment; vendors might omit techniques MITRE thinks are easy, or include techniques MITRE flags as hard. The taxonomy is more a reflection of MITRE's own framework documentation than an independent assessment of vendor reasoning.

W8. Detection quality and false-positive rates are not measured (Strategic)

The entire paper is about coverage breadth: how many techniques have at least one rule. There is no measurement of whether the rules that do exist actually detect the behaviours they claim to detect. Karantzas and Patsakis 2021 found that all 11 EDRs they tested missed at least one attack scenario in a controlled experiment, but Karantzas-style detection-quality testing is out of scope here. A technique can be "covered" in Virkud et al.'s sense by a rule that never fires correctly, or by a rule that produces so many false positives it is effectively disabled in operational deployments. This connects to the endpoint security trade-offs discussed in Module 3, Topic 9, where the course materials note that endpoint security has "Diverse Threat Detection: Uses a range of techniques including signature-based detection, behavioural analysis, heuristics, machine learning, and AI", implying that coverage by any one technique class does not guarantee real-world detection efficacy.

W9. Malicious-entity grouping has known incompleteness with unstated quantitative cost (Operational)

Section 6.1 and Section 8.3 of the paper admit that rules without an explicit mention of a known entity in the rule description are excluded from the entity-grouping analysis. The paper does not estimate what fraction of "true" entity-related rules this excludes, so the headline 12.5% agreement figure across the 9 entities common to all three products is a lower bound of unknown looseness. A bootstrap estimate from a sampled subset, or a hand-coded validation on a stratified sample of rules, could have bounded the missing-completeness, but neither appears in the paper.

W10. KeyBERT keyword extraction adds a methodological black box (Tactical)

KeyBERT is a transformer-based keyword extractor whose outputs are not fully predictable across versions of the underlying language model. The paper uses KeyBERT to identify additional malicious entities beyond those tracked in MITRE and Malpedia, expanding the entity list by 50 (from 141 to 191). This means a non-trivial fraction (26%) of the entity list depends on a single tool's idiosyncrasies. The paper does not report the KeyBERT version, the parameters used, or any sensitivity analysis showing how the entity count or downstream consistency findings change under different KeyBERT configurations. The artefact does ship the pre-computed KeyBERT output, but this means independent verification of the KeyBERT step is not possible without re-running the (heavy, GPU-dependent) extraction.

W11. Risk/severity/confidence metadata is incomplete across vendors (Tactical)

Table 1 of the paper's metadata matrix shows that Carbon Black has no risk score, Splunk has no severity score, and Elastic has no confidence score. The risk/severity filtering analysis in Section 4 (Table 3) shows "/" for missing fields but does not normalise the comparison across vendors. A reader cannot tell whether Carbon Black has lower "high-severity coverage" than Splunk because of genuine difference or because severity is not available for Carbon Black at all. The paper would have benefited from either an imputation strategy (with sensitivity analysis) or a normalised metric that uses whichever of risk/severity/confidence is available per vendor.

W12. Recommendations are aspirational rather than operationalised (Strategic) [course]

Section 8.2 of the paper proposes recommendations such as "develop feedback mechanisms for rule performance sharing" and "build a centralised registry of detection rule metadata." These are reasonable in direction, but the paper provides no prototype, no schema, no evidence that any vendor would adopt them. The course materials' framing of ISO 27001 in Module 3, Topic 10, "ISO 27001 doesn't guarantee security ... [it] is only as effective as the effort put into it", applies here too. Virkud et al. propose what amounts to a meta-framework for ATT&CK feedback, but provide no implementation. By contrast, Sigma's success as a community detection format was driven by an early implementation, not a recommendation. The paper diagnoses the problem strongly but stops short of building a tool that addresses it.

W13. No analysis of update cadence or rule churn (Tactical) [addressed]

Rulesets are not static: vendors add, modify, and retire rules continuously (Vermeer et al. 2022 quantify rule churn in commercial NIDS rulesets at a managed security service provider over a multi-year window). Sigma's public history alone shows hundreds of rule changes per quarter. The paper treats the October 2022 snapshot as if it were the ruleset, providing no estimate of the half-life of its findings. The present report's Sentinel extension partially addresses this by establishing that the Microsoft Sentinel public feed is frozen at August 2022, within two months of the original snapshot, allowing for cross-validation that the findings are not unique to a particular sampling moment.

W14. Accepts ATT&CK as the universe of adversary behaviour (Strategic) [course]

The paper measures vendor coverage of ATT&CK but never asks whether ATT&CK itself is a complete enumeration of adversary behaviour. The Unified Kill Chain framework (Pols 2021), which is taught in INFO 5001 Module 1, Topic 3 as an "Additional Read" alongside ATT&CK, demonstrates that ATT&CK lacks coverage of three phases that occur in real attacks: Pivoting (tunneling traffic through a controlled system to other systems that are not directly accessible), Social Engineering (techniques aimed at the

manipulation of people to perform unsafe actions), and Objectives (the socio-technical objectives of an attack that are intended to achieve a strategic goal). A vendor showing 100% ATT&CK coverage could still miss entire phases of real attacks, for example, pivoting between segmented networks, which is invisible to ATT&CK's tactic enumeration. The paper's critique of ATT&CK-as-metric would be substantially strengthened by acknowledging that ATT&CK itself has architectural blind spots.

W15. Scope is limited to signature-based detection (Tactical) [course]

Module 1, Topic 1 of INFO 5001 teaches that intrusion detection and prevention systems use three methodologies: signature-based detection, anomaly-based detection, and stateful protocol analysis. Virkud et al. analyse exclusively signature-based rule databases. The findings about coverage and labelling consistency therefore do not generalise to anomaly-detection products such as CrowdStrike Falcon's behavioural analytics, Vectra AI's network detection-and-response, or Darktrace's machine-learning models. This is a real scope constraint that the paper would benefit from acknowledging explicitly, particularly since several of the unimplemented techniques in Section 5 (such as living-off-the-land binary abuse) are widely cited as being better detected by anomaly methods.

W16. Artifact ships pre-filter data, not the manual filter decisions (Strategic)

The supplementary materials ship the pre-computed file `combined_rules_annotated_entities.csv` containing 291 unique entity labels across 1,452 rule entries. The paper claims that after manual verification, 191 of these are confirmed malicious entities and the rest are benign terms (such as "powershell", "net", "browser") that were captured by the keyword-extraction pipeline. The artefact does not ship the manual-filter decisions that reduce the 291 to 191. Independent verification of the headline entity count is therefore not possible from the artefact alone; only the case studies and the per-entity analyses are verifiable. This is a transparency gap analogous to W6 (no inter-rater reliability): the paper documents that it did the work, but does not ship the artefacts that would let a reader verify the work was done well.

W17. The artefact omits Carbon Black rule data and the Carbon Black-specific reproduction (Tactical)

The paper analyses Carbon Black, Splunk, Elastic, and Sigma rules in equal weight, but the artefact ships only Splunk, Elastic, and Sigma data. The omission is acknowledged in Section 3, "we received access to the Carbon Black Cloud product via an Educational license and received their permission to use their name and ruleset in this paper", meaning Carbon Black data cannot be redistributed under the licensing terms. As a result, only three of the four headline rulesets are independently verifiable, and any Carbon Black-specific claim (for example, the technique-density distributions for Carbon Black in Figure 3) must be taken on trust. A more reproducible artefact would include either a procedure for independent researchers to acquire equivalent Carbon Black access, or anonymised statistics that preserve the analytical conclusions without redistributing the rule text.

4. Artifact Evaluation

This section evaluates the supplementary artefact for Virkud et al. (released at github.com/avirkud/endpoint-detection-mitreattack, release sec24-ae-final) against the five rubric criteria: Documented, Consistent, Complete, Exercisable, and Results Reproduced. The evaluation is based on a full reproduction attempt conducted on a Windows 11 / Python 3.11.9 environment, which deviates intentionally from the artefact authors' Linux / Python 3.8.10 environment. The reproduction surfaced twenty-seven distinct documentation-worthy events, summarised in the Appendix and referenced throughout this section.

4.1 Documented

The README is concise and structurally complete. It identifies the Python version (3.8.10), points users to the requirements.txt file for dependency installation, lists the data files with one-line descriptions, and identifies the two notebooks corresponding to RQ1 and RQ3. The repository carries the USENIX Security 2024 Artifact Evaluation badges for Available, Functional, and Reproduced, which provides external validation that the artefact passed independent evaluation at the time of publication.

Documentation gaps surfaced during reproduction include: (i) the README does not explain that no RQ2 notebook is shipped because RQ2 is the qualitative coding analysis that has no reproducible computational component; (ii) the README does not warn that Carbon Black data is not included in the artefact due to licensing constraints (this is mentioned only in the paper itself, not in the artefact); (iii) the README does not document which Python platforms were tested: we discovered through reproduction that the requirements.txt was generated via pip freeze on a Linux environment and includes Linux-only CUDA wheels and Unix-only terminal libraries that have no Windows equivalents; (iv) the artefact ships pre-computed KeyBERT outputs (combined_rules_annotated_entities.csv) but does not document that this is a pre-computed superset and that running the KeyBERT cells in RQ3 will reproduce the keyword extraction but not the manual verification step that reduces 291 raw entities to the paper's 191 confirmed entities.

Documentation rating: Adequate for a researcher willing to investigate dependency issues, but missing the cross-platform notes, the Carbon Black licensing context, and the RQ2 omission rationale that would substantially aid reproduction. Inferred rubric tier: Mastery (a notable improvement on average artefacts but with documented gaps).

4.2 Consistent

The artefact is consistent with the paper in the sense that every figure and table reproducible from the shipped data can be regenerated from the shipped notebooks (with the version-drift patches documented in Section 4.4 below). The data files match the rule counts reported in the paper's Table 1 (Splunk 911, Elastic 473, Sigma 2,195), and the ATT&CK technique CSV matches Version 11 (191 unique techniques, 14 tactics). The pre-computed KeyBERT output and the entity-rule mappings produce the same case-study outputs as those shown in the paper's Section 6 (CVE-2021-4034, Meterpreter, FIN7, and the PrintNightmare within-vendor inconsistency case study).

One internal inconsistency was identified during reproduction: the artefact ships combined_rules_annotated_entities.csv with 1,452 entries across 291 unique entity labels, whereas the paper reports 191 verified malicious entities. The discrepancy is explained by the paper's manual verification step (Section 6.1), which filters out benign terms captured by the keyword extractor, but the

artefact does not preserve the manual-filter decisions. This means the paper's aggregate statistics on entity counts cannot be independently re-derived from the artefact; only the per-entity analyses (such as the case studies on specific entities like Nobelium and FIN7) are independently verifiable.

Consistency rating: High for the analyses with shipped computational logic. Lower for aggregate statistics that depend on undocumented manual filtering. Inferred rubric tier: Mastery.

4.3 Complete

Completeness must be evaluated against what the paper claims to ship. The artefact contains the rule data for three of four rulesets (Splunk, Elastic, Sigma; Carbon Black omitted under licensing constraint), the ATT&CK technique mappings, the entity-grouping pre-computations, the two analysis notebooks, and the supplementary PDF with appendix figures. What is missing: (i) the Carbon Black ruleset and any Carbon Black-specific reproduction code; (ii) no notebook for RQ2 because that analysis is qualitative and has no reproducible code; (iii) no record of the manual filtering decisions that reduced the raw 291-entity set to the verified 191; (iv) no plotting code: the notebooks generate the DataFrames that underlie Figures 1, 2, 3, and 4 but do not contain the matplotlib or seaborn code that produces the visualisations in the paper.

The Carbon Black omission is the most consequential gap, since Carbon Black accounts for one quarter of the data in the original analysis and supplies the largest single ruleset by rule-count-per-technique density (the paper reports Carbon Black has 142 rules for T1218 alone). Without Carbon Black, the present reproduction is necessarily limited to the three publicly-available rulesets. The paper-level statistics involving Carbon Black (such as the cross-product Spearman correlations involving CB) must be accepted on the authors' word; only the within-Splunk-Elastic-Sigma analyses are independently verifiable.

Completeness rating: Good for the three publicly-available rulesets. The Carbon Black omission is significant but is forced by the licensing terms and is acknowledged in the paper. Inferred rubric tier: Mastery.

4.4 Exercisable

The artefact does run, but only after applying five distinct version-drift patches. These patches are necessary because the artefact was authored in 2022 against Python 3.8.10 and the surrounding scientific Python ecosystem has advanced through several major versions in the intervening years. The patches required are documented in Table 4.1 below.

#	Issue	Affected file/cell	Workaround
1	np.NaN removed in NumPy 2.0	RQ1 and RQ3 parse_threat_column()	Replace np.NaN with np.nan (lowercase)
2	DataFrame.applymap deprecated in pandas 2.1	RQ1 technique-count-per-tactic cell	Replace .applymap(len) with .map(len)
3	requirements.txt contains Linux-only wheels (nvidia-* CUDA, triton, pexpect,	requirements.txt	Skip pip install -r; install curated minimal set (pandas, numpy, scipy, nltk, matplotlib, seaborn, matplotlib-venn, jupyter, ipykernel) only

#	Issue	Affected file/cell	Workaround
	ptyprocess)		
4	NLTK 3.8.2+ requires punkt_tab in addition to punkt	RQ3 NLTK download cell	Add nltk.download('punkt_tab') alongside nltk.download('punkt')
5	PyTorch / KeyBERT stack unavailable on minimal Windows install	RQ3 KeyBERT cells (cells 19–30)	Skip these cells; use the pre-computed combined_rules_annotated_entities.csv directly in the Case Studies section. This is verified to produce the same outputs as running the full pipeline.

A sixth issue (np.NaN recurrence in RQ3) is a duplicate of issue 1 but worth documenting because the fix must be applied in both notebooks separately; neither notebook imports from the other. This is itself a minor artefact design issue: shared helper functions could have been placed in a single Python module and imported into both notebooks, which would have meant a single point of patching for any future ecosystem changes.

After applying these five patches, both notebooks run end-to-end without further intervention. The reproduction was conducted on Windows 11 with Python 3.11.9 in a fresh virtual environment, with no special hardware (no GPU required for the chosen execution path) and approximately 1.2 GB of disk for the data, notebooks, and environment combined.

Exercisable rating: Runs after documented workarounds. The version drift over 18 months between artefact authorship and reproduction is a real reproducibility friction that we argue (in Section 6) is itself a finding about the half-life of security-research artefacts. Inferred rubric tier: Exceeds (the workarounds are explicit and reproducible by a third party from the documentation provided).

4.5 Results Reproduced

All headline numerical results of the paper that depend on the publicly-available data were reproduced to three decimal places. This section walks through the reproductions and lists any deviations.

4.5.1 RQ1: Coverage analysis

The technique-count-per-tactic table (the data behind Figure 1 of the paper) was reproduced exactly for the three available rulesets. Selected values are shown in Table 4.2 below; the full table covers all 14 ATT&CK tactics.

Tactic	Splunk	Elastic	Sigma
discovery	15	15	25
impact	10	3	12
command-and-control	6	8	14
exfiltration	4	2	6

Tactic	Splunk	Elastic	Sigma
credential-access	10	9	13
reconnaissance	4	0	4
collection	6	6	13
defense-evasion	25	24	32
execution	6	9	9
persistence	13	15	18
privilege-escalation	11	12	12
initial-access	6	6	9
resource-development	2	1	4
lateral-movement	2	4	7

All values match the paper's reported counts. Note that "reconnaissance" shows zero techniques for Elastic, which is consistent with the paper's observation that Elastic's ruleset does not target the reconnaissance tactic.

4.5.2 RQ1: Technique density

The paper reports that 9.9–13.1% of techniques have exactly one associated rule, 29.8–32.5% have between one and five rules, and 1.6–2% have more than fifty rules. The reproduction produces:

Density category	Splunk	Elastic	Sigma	Paper range
Exactly 1 rule	19 (9.9%)	25 (13.1%)	26 (13.6%)	9.9–13.1%
1 to 5 rules	57 (29.8%)	62 (32.5%)	67 (35.1%)	29.8–32.5%
More than 50 rules	4 (2.1%)	0 (0.0%)	17 (8.9%)	1.6–2% (commercial)

The first two ranges match the paper exactly. Elastic having zero techniques with more than 50 rules is consistent with the paper's narrative on Elastic having a smaller, more focused ruleset. Sigma's higher rate (8.9%) reflects its crowdsourced nature and is consistent with the paper's appendix treatment of Sigma.

4.5.3 RQ1: Spearman rank correlations

The paper's headline statistical analysis, the rank correlations between pairs of rulesets, was reproduced to four decimal places. The values are shown in Table 4.4 below.

Pair	Reproduced ρ	Reproduced p-value	Paper-reported value
Splunk vs Elastic	0.6389	2.69×10^{-23}	0.639
Splunk vs Sigma	0.7010	1.47×10^{-29}	0.701
Elastic vs Sigma	0.7617	1.82×10^{-37}	0.762

All three correlations match the paper's reported values to three decimal places, and all p-values are well below 0.001. This validates one of the paper's central quantitative claims, that vendors share similar preferences for which ATT&CK techniques to prioritise, and provides a benchmark against which the Sentinel extension in Section 5 will be measured.

4.5.4 RQ3: Case studies of labelling inconsistency

The paper's Section 6 presents four case studies of cross-vendor labelling disagreement. All four were reproduced from the artefact and confirm the paper's findings.

(i) CVE-2021-4034 (PwnKit): Elastic rule e69 tags the polkit pkexec privilege-escalation vulnerability with T1574 (Hijack Execution Flow) plus T1068 (Exploitation for Privilege Escalation). Splunk rule s489 tags the same vulnerability with T1068 only. Both labels are defensible characterisations of a local privilege escalation that exploits an environment-variable injection in a SUID binary, but the two vendors apply different labels to the same threat.

(ii) Meterpreter named-pipe impersonation: Elastic e479 detects the same observable behaviour (the Cmd/PowerShell echo-to-pipe pattern used by Metasploit's getsystem command) as Splunk s229, but Elastic tags it with T1134 (Access Token Manipulation) while Splunk tags it with four techniques (T1059 Command and Scripting Interpreter, T1059.003 Windows Command Shell, T1543.003 Windows Service, T1543 Create or Modify System Process). Same detection logic; four different ATT&CK techniques between the two vendors.

(iii) FIN7 nslookup tactic disagreement: Splunk rule s324 detects the nslookup-with-record-type-and-retry pattern used by FIN7's JS implant and tags it with T1048 (Exfiltration Over Alternative Protocol) under the Exfiltration tactic. Elastic's FIN7 rules covering similar DNS-misuse behaviour tag it as T1568 / T1071 (Dynamic Resolution / Application Layer Protocol) under the Command and Control tactic. Same observable; different ATT&CK tactics. This is the most damaging case study because it shows vendors disagreeing on the phase of the kill chain at which the behaviour occurs, not just on the technique within a phase.

(iv) Within-vendor inconsistency on CVE-2021-34527 (PrintNightmare): Across the seven Splunk rules covering PrintNightmare, six are tagged with T1547 (Boot or Logon Autostart Execution) or its sub-technique T1547.012 (Print Processors), but one (s687) is tagged with T1068 (Exploitation for Privilege Escalation). Elastic's two PrintNightmare rules both use T1068. The within-Splunk inconsistency is the most striking case: the same vendor applies different ATT&CK techniques to the same CVE across different rules.

Results Reproduced rating: All numerical claims from RQ1 that depend on publicly-available data match the paper to three decimal places; all four RQ3 case studies confirm the paper's claims of labelling inconsistency. The Carbon Black-specific claims could not be independently reproduced (limitation W17). Inferred rubric tier: Exceeds (the reproduction covers every reproducible analysis presented in the paper, with deviations clearly identified and logically explained).

5. Improvement: Extending the Analysis with Microsoft Sentinel

5.1 Motivation

Weakness W2 in Section 3.2 identifies Microsoft Sentinel as the most consequential omission from the original paper. Sentinel has been identified as a Leader in recent Gartner Magic Quadrant assessments for SIEM, was publicly available at the time of Virkud et al.'s data collection (the public MSTIC feed snapshot dates to August 2022, two months before the paper's October 2022 ruleset snapshot), and exposes a cloud-native, identity-focused detection architecture that is structurally distinct from the on-host EDR products in the paper.

The case for including Sentinel is strengthened by a course-level consideration. Module 2, Topic 4 of INFO 5001 uses the 2023–2024 Microsoft cyberattack by Nobelium / Midnight Blizzard as a flagship case study of cyber-intrusion investigation. That attack employed password spraying (T1110.003) against legacy non-production tenant accounts (T1078, Valid Accounts) to gain initial access and then access corporate email (T1114, Email Collection). These are precisely the techniques that a cloud-native SIEM ingesting Azure AD logs is built to detect, and that an on-host EDR consuming endpoint process telemetry would be expected to detect less effectively.

Combining the methodological case (W2: missing major vendor) with the course-anchored case (the Midnight Blizzard attack class is the canonical Sentinel use-case and is taught in the course) motivates a pre-registered hypothesis. Before any analysis is conducted, we commit to the following claim:

Pre-registered hypothesis: Microsoft Sentinel, as a cloud-native SIEM with strong identity and cloud-workload focus, will show measurably higher coverage of techniques relevant to cloud and identity attack chains (specifically T1078 Valid Accounts, T1098 Account Manipulation, T1530 Data from Cloud Storage, T1110 Brute Force including Password Spraying) than the three on-host EDR products in the original paper, and may show comparable or lower coverage of techniques requiring on-host telemetry (specifically T1547 Boot or Logon Autostart Execution, T1543 Create or Modify System Process, T1574 Hijack Execution Flow, T1055 Process Injection).

The hypothesis is structured to be falsifiable. If Sentinel's rule counts for cloud/identity techniques are not greater than Splunk and Elastic's rule counts, the hypothesis fails. If Sentinel's rule counts for host-only techniques are not less than Splunk and Elastic's, the hypothesis fails. The result either way is informative: confirmation supports the claim that ATT&CK coverage is partly an artefact of telemetry architecture; refutation would imply that cloud-native SIEMs are not, in fact, structurally distinct from on-host EDRs in their coverage profile, which would itself be a counter-intuitive and therefore interesting finding.

5.2 Methodology

Microsoft maintains a public, ATT&CK-tagged CSV of Sentinel detection rules in the MSTIC public feeds repository at github.com/microsoft/mstic/blob/master/PublicFeeds/MITREATT%26CK/MicrosoftSentinel.csv. The CSV contains 10,132 raw rows with 18 columns spanning Tactic, TechniqueId, Platform, DetectionType, DetectionService, DetectionId, DetectionName, DetectionDescription, ConnectorId, DataTypes, Query, QueryFrequency, QueryPeriod, TriggerOperator, TriggerThreshold, DetectionSeverity, DetectionUrl, and IngestedDate. All entries carry an IngestedDate of 2022-08-07, confirming the feed is a single snapshot rather than a rolling export.

Transforming the Sentinel CSV into a format structurally comparable to Virkud et al.'s Splunk, Elastic, and Sigma DataFrames required four methodological decisions. Each decision is documented here with the rationale, since the choices have direct consequences for the comparison.

5.2.1 Filter to Analytics rules only

Sentinel's DetectionType column has three values: Analytics (4,308 rows), Hunting (3,607 rows), and Fusion (2,217 rows). Analytics rules are active detection rules that fire automated alerts, directly equivalent to Splunk's detection rules, Elastic's production-maturity rules, and Sigma's stable rules. Hunting queries are investigative tools that SOC analysts run on demand to search for indicators of compromise. Fusion detections are outputs of Microsoft's ML-driven correlation engine, which combines signals from multiple sources rather than firing on individual rule patterns.

For apples-to-apples comparison with Virkud et al.'s rule-counting methodology, we filter to DetectionType == "Analytics" only. Including Hunting queries would inflate Sentinel's coverage with rules that are not active in the same operational sense as the comparators. Including Fusion would introduce a different class of detection entirely (correlation-based rather than signature-based) and would violate the paper's scope of signature-based detection rulesets. The Analytics-only filter is the methodologically conservative choice and is documented in the extension's adapter module.

5.2.2 Deduplicate by DetectionId across platforms

The Sentinel CSV represents each rule once per supported platform: the same rule covering Azure, Windows, and Linux appears as three rows with identical DetectionId values. After Analytics filtering, 3,107 rows reduce to 349 unique rules when deduplicated by DetectionId. Platforms are aggregated into a list per rule and preserved as metadata, so platform information is not lost; it simply moves from the row dimension to a column.

5.2.3 Drop rows with invalid TechniqueId

Sentinel's CSV includes 3,126 rows with no TechniqueId (some rules are platform-level detections that do not map to specific ATT&CK techniques) and a small number of rows with the placeholder string "N.A.". These are excluded from the analysis, matching the Virkud et al. methodology of analysing only rules that have ATT&CK technique annotations.

5.2.4 Apply parent-technique aggregation (drop_subtechniques)

The paper's analysis truncates sub-techniques to their parent (T1003.001 → T1003), matching the approach taken in Virkud et al.'s drop_subtechniques helper. The Sentinel adapter applies the same transformation for consistency. This is a meaningful choice (keeping sub-techniques would slightly inflate the coverage number for all rulesets, including the comparators), and we follow the paper's convention.

5.2.5 Implementation

The extension is implemented as two modular Python modules and one Jupyter notebook. The structure mirrors the modular separation of the original artefact:

- sentinel_adapter.py: loads, filters, deduplicates, and transforms the Microsoft Sentinel CSV into a Virkud-compatible DataFrame, and provides analysis helpers (technique coverage summary, Sentinel-unique technique identification, hypothesis test, Spearman correlation alignment).

- `vir kud_loader.py`: wraps the data-loading logic from the original RQ1 notebook into reusable functions, including the `np.NaN-to-np.nan` patch documented in Section 4.4.
- `sentinel_rq1_analysis.ipynb`: a clean analysis notebook that imports both modules, loads all five rulesets, and runs the three core analyses (coverage summary, hypothesis test, Spearman correlations). The notebook produces the figures and tables referenced in Section 5.3.

The full source for both Python modules and the notebook is included in the project's submission directory under `extension/notebooks/`. All outputs (CSV summaries, unique technique lists) are saved to `extension/outputs/` for inclusion in this report.

5.3 Results

The Sentinel extension produces three converging findings that confirm the pre-registered hypothesis at high magnitude and add a third failure mode to Vir kud et al.'s critique of ATT&CK-as-security-metric.

5.3.1 Finding 1: Coverage breadth

After applying the methodology in Section 5.2, the Microsoft Sentinel ruleset reduces to 349 unique Analytics rules covering 81 unique parent-technique IDs in ATT&CK Version 11. This corresponds to a coverage of 41.4% of the 191 techniques in ATT&CK v11. Table 5.1 shows the coverage comparison across all five rulesets.

Ruleset	# Rules	# Unique Techniques	% Coverage (ATT&CK v11)
Splunk	911	100	52.4%
Elastic	473	92	48.2%
Sigma	2,195	151	79.1%
Sentinel	349	81	41.4%

Sentinel sits just below the commercial range that Vir kud et al. report (Splunk 52.4%, Elastic 48.2%, with Carbon Black 55% per the paper). The 41.4% figure extends the commercial range from "48–55%" to "41–55%" when cloud-native SIEMs are included. This is the first finding: Sentinel's aggregate breadth is comparable to but slightly lower than the on-host EDR products, despite Sentinel having the smallest absolute rule count (349 versus Splunk's 911).

On its own, this aggregate figure is uninteresting; it could be explained by Sentinel simply being less mature, or having a narrower scope. The interesting question is what is in the 41.4%, which is the subject of the second finding.

5.3.2 Finding 2: Pre-registered hypothesis confirmed at high magnitude

Table 5.2 shows the per-technique rule counts for the pre-registered cloud/identity techniques (top half) and the pre-registered host-only techniques (bottom half). The hypothesis predicts that the Sentinel column should exceed the Splunk and Elastic columns in the top half and fall below them in the bottom half.

Technique	Name	Splunk	Elastic	Sigma	Sentinel
T1078	Valid Accounts	39	13	52	78
T1098	Account Manipulation	6	7	23	38
T1110	Brute Force (incl. Password Spraying)	15	11	22	29
T1136	Create Account	11	2	15	7
T1530	Data from Cloud Storage	2	0	0	1
T1556	Modify Authentication Process	3	5	4	3
T1547	Boot or Logon Autostart Execution	15	23	50	2
T1543	Create or Modify System Process	16	26	46	1
T1546	Event Triggered Execution	14	14	54	8
T1574	Hijack Execution Flow	9	9	64	1
T1055	Process Injection	21	12	35	1
T1014	Rootkit	3	0	1	0

The pre-registered hypothesis is strongly confirmed. For the three most prominent cloud/identity techniques, Sentinel has substantially more rules than either Splunk or Elastic: 78 rules for T1078 Valid Accounts versus Splunk's 39 and Elastic's 13 (a 2× to 6× margin); 38 rules for T1098 Account Manipulation versus Splunk's 6 and Elastic's 7 (a 5× to 6× margin); and 29 rules for T1110 Brute Force / Password Spraying versus Splunk's 15 and Elastic's 11 (a 2× to 3× margin). The T1078 finding is particularly striking because Sentinel has the smallest total ruleset (349 rules) yet has more rules dedicated to Valid Accounts alone than either of the comparators.

The host-only techniques show the inverse pattern at even greater magnitude. T1547 has 2 Sentinel rules versus 15 Splunk and 23 Elastic. T1543 has 1 Sentinel rule versus 16 Splunk and 26 Elastic. T1574 has 1 Sentinel rule versus 9 in each of Splunk and Elastic. T1055 has 1 Sentinel rule versus 21 in Splunk and 12 in Elastic. The ratio is approximately 5× to 26× fewer Sentinel rules for these host-focused techniques compared to the on-host EDR products.

The Sigma column provides a useful control: as a crowdsourced ruleset that aggregates contributions from analysts across many architectures, Sigma's counts are uniformly high for both cloud and host techniques, reflecting its broader scope rather than a particular architectural bias.

Twelve techniques are covered by Sentinel but not by either Splunk or Elastic: T1008, T1012, T1030, T1041, T1052, T1072, T1213, T1496, T1528, T1563, T1571, and T1578. Three of these are explicitly cloud-architectural: T1213 (Data from Information Repositories: SharePoint, Confluence), T1528 (Steal Application Access Token, the OAuth/Azure AD attack class), and T1578 (Modify Cloud Compute Infrastructure, Azure/AWS attacks). These cannot be detected from on-host telemetry alone; Sentinel covers them because it ingests cloud control-plane logs that are not available to host-based EDR

products. Conversely, 57 techniques are covered by Splunk or Elastic but not by Sentinel, and the majority are host-focused discovery and persistence techniques (T1016 System Network Configuration Discovery, T1033 System Owner / User Discovery, T1057 Process Discovery, T1082 System Information Discovery, T1218 Signed Binary Proxy Execution, T1220 XSL Script Processing, etc.) that require process and filesystem visibility on the endpoint.

5.3.3 Finding 3: Spearman correlations quantify the divergence

Section 4.5.3 reproduced the paper's within-Virkud Spearman rank correlations: $\rho = 0.6389$ (Splunk–Elastic), 0.7010 (Splunk–Sigma), 0.7617 (Elastic–Sigma). Adding Sentinel as a fifth ruleset produces three additional correlation pairs, shown in Table 5.3.

Pair	Spearman ρ	p-value	Comparison to within-Virkud
Splunk vs Elastic (paper)	0.6389	2.69×10^{-23}	n/a (within-Virkud)
Splunk vs Sigma (paper)	0.7010	1.47×10^{-29}	n/a (within-Virkud)
Elastic vs Sigma (paper)	0.7617	1.82×10^{-37}	n/a (within-Virkud)
Sentinel vs Splunk	0.3927	1.92×10^{-8}	38% lower than Splunk–Elastic
Sentinel vs Elastic	0.4461	9.93×10^{-11}	30% lower than Splunk–Elastic
Sentinel vs Sigma	0.5003	1.72×10^{-13}	34% lower than Elastic–Sigma

All three Sentinel correlations are statistically significant ($p < 0.001$), so the rank ordering is not random; Sentinel agrees with the other rulesets more than chance would predict. However, the magnitude of agreement is substantially lower than the within-Virkud range. The within-Virkud correlations fall between $\rho = 0.64$ and $\rho = 0.76$, which the paper interprets as evidence that vendors share similar preferences for which techniques to detect. The Sentinel correlations fall between $\rho = 0.39$ and $\rho = 0.50$, a drop of approximately 30–38% in rank correlation compared to within-Virkud pairs.

The Spearman result quantifies what the hypothesis test in Finding 2 shows qualitatively. Sentinel does not just have different volumes of rules per technique; it has a structurally different ordering of which techniques it prioritises. The cloud-versus-host architectural split shows up not only in counts but in ranking. Sentinel's technique-priority profile is genuinely distinct from the three rulesets in the original paper.

5.4 Discussion

5.4.1 A third failure mode of ATT&CK-as-metric

Virkud et al. argue that ATT&CK coverage is an unreliable security metric because (a) the headline coverage figure is inflated by low-severity rules that SOC analysts would deprioritise in practice (Finding from Section 4 of the paper), and (b) different vendors apply different ATT&CK labels to the same threats, so the metric is not commensurable across products (Finding from Section 6 of the paper). The present extension demonstrates a third failure mode:

Third failure mode: ATT&CK coverage is partly an artefact of telemetry architecture, not just detection effort. A cloud-native SIEM and an on-host EDR cannot meaningfully be compared on

technique coverage because they have access to fundamentally different log sources. Sentinel covers techniques (T1213, T1528, T1578) that the on-host EDRs structurally cannot cover, while the on-host EDRs cover techniques (T1218, T1220, T1547, T1543) that Sentinel cannot see from cloud control-plane logs alone.

This is structurally distinct from the paper's second failure mode (vendor labelling inconsistency). Vendor labelling inconsistency assumes both vendors could in principle detect the same threat and disagree about how to label what they detected. The third failure mode argues that some vendors cannot detect some threats in principle, because they do not have the telemetry. ATT&CK coverage scores for cloud-native SIEMs and on-host EDRs are not directly comparable not because the vendors disagree about labels, but because they are being measured against partially-disjoint subsets of the framework.

The implication for procurement, cyber insurance, and the threat-informed defence movement is that ATT&CK coverage cannot be used as a comparative metric across architectural categories without explicit normalisation by data source. The Microsoft 365 / Azure AD log universe is not commensurable with the Sysmon / EDR telemetry universe; comparing coverage figures derived from them is comparing the wrong quantities.

5.4.2 Connection to the Midnight Blizzard / Nobelium case study

Module 2, Topic 4 of INFO 5001 presents the 2023–2024 Microsoft cyberattack by Nobelium as the flagship case study for cyber-intrusion investigation. The attack chain, comprising password spraying (T1110.003) against legacy non-production tenants, valid-account abuse (T1078), and email collection (T1114), is precisely the attack class for which Sentinel has by far the highest rule density. Sentinel has 78 rules for T1078 alone, more than Splunk and Elastic combined. This is consistent with the architectural argument in Section 5.4.1: cloud and identity attacks are detected by SIEMs that ingest cloud control-plane logs, not by EDRs that consume endpoint process telemetry. The Midnight Blizzard attack was eventually attributed and investigated using exactly the telemetry sources that Sentinel rules query.

The case study also illuminates a subtle finding from Virkud et al.'s consistency analysis. Nobelium is one of the 9 malicious entities the paper identifies as being explicitly addressed by all three commercial products in its Figure 6. The paper reports that even with all three vendors targeting Nobelium, ATT&CK label agreement across products is low. The present extension adds the observation that even if Sentinel had been included in the original paper, the cross-vendor consistency would likely have been even lower: Sentinel's technique profile for Nobelium-class attacks (heavily weighted toward T1078, T1098, T1110) is structurally distinct from the on-host EDRs' coverage of the same threat. The ATT&CK-coverage inconsistency Virkud et al. document is, in this view, partly a consequence of vendors with different telemetry making locally-correct choices that happen to disagree in ATT&CK space.

5.4.3 Limitations of the extension

The extension has limitations that should be noted in interpreting its conclusions. First, the public Microsoft Sentinel feed is a snapshot from August 2022 and has not been refreshed in the public MSTIC repository since. Newer rules added to the Azure Sentinel community repository on GitHub are not in the public feed and were not included in this analysis. The extension therefore measures Sentinel as of mid-2022, which is approximately contemporaneous with Virkud et al.'s October 2022 snapshot; the comparison is time-aligned rather than time-shifted, which is methodologically clean but means we cannot make claims about how Sentinel has evolved since.

Second, the extension excludes Sentinel's Hunting queries and Fusion detections (Section 5.2.1). Including them would change the picture: Sentinel ships an additional 3,607 Hunting queries that are not active detections in the operational sense but are part of the product's overall threat-coverage story. A reader who interprets Sentinel's 41.4% coverage as the totality of Sentinel's ATT&CK posture would be missing the Hunting and Fusion contributions. We argue the exclusion is correct for apples-to-apples comparison with Virkud et al., but it is a methodological choice that future work could revisit.

Third, the extension does not address Virkud et al.'s qualitative analyses (RQ2 on unimplemented techniques and the manual entity-verification step in RQ3). The Sentinel CSV does ship rule descriptions that could be subjected to KeyBERT-style keyword extraction for entity grouping, but the manual verification step would require coding effort beyond the scope of this report. We flag this as a direction for future work in Section 7.

6. Discussion

6.1 Connecting the findings to course frameworks

The findings of this report intersect with several frameworks taught in INFO 5001 in ways that strengthen both the analysis and the underlying course material.

6.1.1 ATT&CK-as-metric and the ISO 27001 "checkbox compliance" trap

Module 3, Topic 10 of INFO 5001 introduces ISO 27001 as a compliance framework that "doesn't guarantee security ... [but] provides a structure that keeps security organised and measurable." The same module flags four limitations of ISO 27001, paraphrased here: organisations may treat it as a checkbox task, focus on paperwork over technical security, accept lenient audits, and fail to extend security beyond compliance requirements.

Virkud et al.'s critique of ATT&CK-as-metric reads as a parallel set of limitations. The paper argues that ATT&CK coverage is treated as a checkbox metric by vendors (S12), is reported as a breadth figure that hides depth (W3), is accepted without independent validation of the labels (W4), and fails to extend to the architecturally-divergent realities of different telemetry sources (the present extension's third failure mode). The structural parallel is significant: both ISO 27001 and ATT&CK are frameworks that organise security thinking but can be reduced to checkbox compliance when treated as ends in themselves. The course's teaching on ISO 27001 prepares the analyst to read Virkud et al.'s critique as an instance of a more general pattern about compliance frameworks.

6.1.2 The Unified Kill Chain as a structural critique of ATT&CK

Pols' Unified Kill Chain (2021), included as an "Additional Read" in Module 1, Topic 3, falsifies the deterministic assumption of Lockheed Martin's original Cyber Kill Chain, namely that an attacker "must progress successfully through each stage of the chain." The UKC argues that real attacks bypass phases, occur out of sequence, or loop, and that ATT&CK itself lacks coverage of three phases that appear in real attacks: Pivoting, Social Engineering, and Objectives.

The UKC critique extends Virkud et al.'s argument in a direction the original paper does not pursue. If ATT&CK is structurally incomplete as an enumeration of adversary behaviour (UKC argument), and if vendor coverage of ATT&CK is in turn structurally bounded by telemetry architecture (the present extension's argument), then the picture of "ATT&CK technique coverage as security metric" looks doubly compromised: it measures a fraction of what vendors can see, of a fraction of what the framework enumerates, of a fraction of what real attackers do. The composition of fractions is a different kind of measurement than the headline coverage figure suggests.

6.1.3 Cyber threat intelligence layers and the metric framing

Module 2, Topic 4 of INFO 5001 organises cyber threat intelligence into three layers: tactical (specific tools, techniques, and procedures), operational (specific upcoming threats or ongoing campaigns), and strategic (long-term trends and high-level positioning). The CTI framework provides a clean way to see where Virkud et al.'s critique lands and where it does not.

At the tactical layer, the paper's coverage analysis (RQ1) and the present extension's Sentinel addition speak to specific techniques and how many rules each ruleset has for each one. At the operational layer, the paper's entity-grouping analysis (RQ3) and the present extension's Midnight Blizzard / Nobelium discussion speak to how products perform against specific named threats. At the strategic layer, the

paper's recommendations (Section 8.2 of Virkud et al.) and the present extension's third failure mode speak to how ATT&CK-as-metric should be used at the procurement and policy level. Each layer is informative, and the layered framing prevents collapsing the discussion into "vendor X is better than vendor Y", which would be the wrong question to ask of the data presented in both the original paper and this extension.

6.1.4 Defence-in-depth and endpoint as one layer

Module 3, Topic 9 of INFO 5001 introduces defence-in-depth as the layering of perimeter security, network segmentation, access control, endpoint security, application security, monitoring, and incident response. The course materials are explicit that endpoint security has both advantages (granular protection, diverse threat detection, off-network protection) and disadvantages (device dependency, performance impact, management complexity).

Virkud et al.'s entire scope is the endpoint layer of defence-in-depth, and only one detection methodology within that layer (signature-based, per W15). The present report's extension adds Sentinel, which sits at the boundary between endpoint and cloud / identity layers. The full picture of an organisation's defensive posture cannot be inferred from coverage data for any single layer; it requires composition of measurements across layers. This is consistent with the defence-in-depth framing in the course and is a reason to be cautious about any procurement decision that uses a single coverage number as its primary criterion.

6.1.5 Australian context: the Essential Eight and the SOCI Act

The Australian Cyber Security Centre's Essential Eight (introduced in Module 2, Topic 4) provides a prescriptive list of eight mitigation strategies: application control, patch applications, configure Microsoft Office macro settings, user application hardening, restrict administrative privileges, patch operating systems, multi-factor authentication, and regular backups. The Essential Eight is a prescriptive framework: it tells organisations what to do, whereas ATT&CK is a descriptive framework: it tells organisations what attackers do. The two are complementary, but their complementarity is conditional on using each for its proper purpose.

A procurement decision that uses ATT&CK coverage as its primary metric while ignoring Essential Eight implementation inverts the proper relationship between defensive prescription and threat enumeration. The Essential Eight tells you whether the organisation has implemented the controls; ATT&CK tells you what attackers might do. The latter is informative only against a baseline of the former. For Australian organisations subject to the Security of Critical Infrastructure Act 2018 (SOCI Act, also Module 2, Topic 4), this distinction is operationally important: incident reporting obligations under SOCI are tied to specific impacts on critical infrastructure assets, not to ATT&CK coverage scores. The compliance framework that applies in practice is prescription-led, not framework-coverage-led.

6.2 The cross-platform reproduction as a secondary contribution

A second-order observation from the reproduction work is worth highlighting. The artefact authors developed in WSL2 on a Linux substrate (evident from the WSL mount paths in the notebook outputs shipped with the artefact). Their requirements.txt was generated by pip freeze on Linux and includes Linux-only CUDA wheels, Linux-only terminal libraries, and a pinned PyTorch / KeyBERT stack that requires several gigabytes of dependencies. Reproducing the artefact on native Windows surfaced five distinct version-drift workarounds (Section 4.4) and required curation of a minimal dependency set that omits the unavailable Linux-only packages.

This experience is itself informative about the state of security-research reproducibility. A USENIX Security AE-Reproduced badge indicates that the artefact was reproduced by an independent evaluator at the time of publication. Eighteen months later, ecosystem drift has introduced friction that was not present at evaluation time: NumPy 2.0 broke `np.NaN`, pandas 2.1 deprecated `DataFrame.applymap`, NLTK 3.8.2 split `punkt` into two packages. None of these changes were predictable at the time of artefact submission. The implication is that even excellent artefact stewardship has a half-life, and the cost of reproducing security research grows with the elapsed time between publication and replication attempt.

The present report's twenty-seven-entry reproduction log is, in a small way, a contribution to the literature on artefact reproducibility. The log provides a documented path through the version drift that any future researcher reproducing Virkud et al. on a modern environment will encounter. We argue that future security-research artefacts would benefit from including a "compatibility notes" file alongside the `requirements.txt`, a living document that future maintainers (or independent researchers) can update with the version-drift fixes they discover. This is a modest but actionable recommendation that emerges naturally from doing the reproduction rather than reading about it.

6.3 Implications for the threat-informed defence movement

The threat-informed defence movement, championed by MITRE's Center for Threat-Informed Defense, MITRE Engenuity ATT&CK Evaluations, and various vendor-side initiatives, relies on ATT&CK coverage as a measurable proxy for defensive capability. Virkud et al.'s paper, and the present extension, do not invalidate the movement. ATT&CK is still the best available common vocabulary for describing adversary behaviour, and threat-informed defence is still preferable to control-driven or audit-driven approaches that ignore actual attacker activity.

What the combined evidence does suggest is that ATT&CK coverage scores should be reported with explicit context. A score is only interpretable in conjunction with: (a) the ruleset's severity / risk distribution (Finding from Section 4 of Virkud et al.); (b) the labels the vendor uses for which threats (Findings from Section 6 of Virkud et al.); and (c) the architectural class of the detection system and the telemetry it has access to (the present extension's third failure mode). Coverage scores reported without all three pieces of context are difficult to interpret and easy to misuse.

For practitioners, the practical implication is that ATT&CK Navigator overlays should be annotated with severity thresholds, with confidence intervals reflecting labelling uncertainty, and with architectural class identifiers (cloud SIEM, on-host EDR, network IDS, etc.). For procurement teams, the implication is that ATT&CK coverage cannot be compared across architectural categories without normalisation by data source. For researchers, the implication is that future ATT&CK-coverage measurement studies should include multiple architectural categories in their dataset to avoid concluding from a single-architecture sample that ATT&CK is "covered" or "not covered" by some industry-wide percentage.

7. Conclusion and Future Work

7.1 Summary of contributions

This report critically analysed Virkud et al.'s 2024 USENIX Security paper "How does Endpoint Detection use the MITRE ATT&CK Framework?" and extended it with a fifth ruleset that the original work omitted. The critical analysis identified twelve substantive strengths (anchored where relevant in the CTI tactical/operational/strategic framework taught in INFO 5001) and seventeen substantive weaknesses, three of which are addressed directly by the Microsoft Sentinel extension. The artefact evaluation reproduced all publicly-reproducible findings of the paper to three decimal places of agreement, documenting twenty-seven discrete reproduction events along the way.

The Microsoft Sentinel extension makes three contributions. First, it adds the largest cloud-native SIEM by deployment share to the set of rulesets analysed in the original paper, extending the commercial coverage range from "48–55%" to "41–55%". Second, it confirms a pre-registered hypothesis that Sentinel's coverage profile is systematically biased toward cloud and identity techniques (T1078, T1098, T1110) at the expense of host-only techniques (T1547, T1543, T1574, T1055), with the cloud/identity differences exceeding the host differences by an order of magnitude in some cases. Third, it provides a Spearman rank correlation analysis showing that Sentinel's technique-priority ordering is meaningfully distinct from the on-host EDRs in the original paper ($\rho = 0.39\text{--}0.50$, versus the within-paper range of $\rho = 0.64\text{--}0.76$).

The interpretive contribution is to add a third failure mode to Virkud et al.'s critique of ATT&CK-as-security-metric: ATT&CK coverage is partly an artefact of telemetry architecture, not just detection effort, and is therefore not commensurable across architectural categories.

7.2 Limitations

The work has limitations. The Sentinel CSV is a single snapshot from August 2022 and does not reflect the current state of the Sentinel detection content as of 2026. The Carbon Black ruleset could not be reproduced (licensing constraint W17), so the present analysis is limited to four of the five rulesets we would ideally include. The Sentinel extension excludes Hunting queries and Fusion detections, which is methodologically correct for comparison with the original paper but means it does not capture the full Sentinel ATT&CK posture. The qualitative analyses in the original paper (RQ2 on unimplemented techniques) were evaluated but not re-conducted on Sentinel data. The cross-platform reproduction was completed on a single Windows / Python 3.11 environment; reproducibility on macOS or older Python versions was not tested.

7.3 Future work

Several extensions of the present work would strengthen the analysis and bring it closer to publishable form. First, applying the paper's qualitative methodology (open coding of unimplemented techniques) to Sentinel would surface whether Sentinel's "unimplemented" set has different structural reasons than the on-host EDRs (we expect cloud-side telemetry limits rather than the host-side limits the paper identifies). Second, applying the paper's entity-grouping methodology (KeyBERT keyword extraction plus manual verification) to Sentinel would allow direct measurement of cross-architectural labelling inconsistency for shared malicious entities like Nobelium and FIN7. Third, extending the extension to include further cloud-native and SIEM rulesets (such as Google Chronicle's public-facing detection content, or AWS's GuardDuty findings) would test whether the architectural-asymmetry finding

generalises beyond Sentinel specifically. Fourth, longitudinal analysis comparing the August 2022 Sentinel snapshot to a current snapshot would directly measure the rule-churn issue that Virkud et al. do not address (W13). Fifth, the present work's recommendation that ATT&CK coverage scores be reported with explicit architectural class identifiers could be operationalised as a small extension to MITRE's ATT&CK Navigator JSON schema, which would make the architectural context discoverable in the standard tools.

Most ambitiously, the third failure mode identified here, that ATT&CK coverage is partly an artefact of telemetry architecture, could be formalised as a quantitative measure of "telemetry coverage" that complements technique coverage. A rule cannot detect what its log sources cannot see; the relationship between ATT&CK techniques and the log sources required to detect them is partially documented in MITRE's ATT&CK Data Sources project but has not, to our knowledge, been combined with vendor rule data to produce a "telemetry-normalised coverage" metric. We believe such a metric would be a substantive contribution to the threat-informed defence literature, and the Sentinel extension presented here is a first step in that direction.

7.4 Closing remark

Virkud et al. argue that the MITRE ATT&CK framework, described in Module 1, Topic 3 of INFO 5001 as "a structured list of known attacker behaviours", is being asked to do more work than it is built for. Marketing claims, procurement decisions, and cyber-insurance pricing have all begun to treat ATT&CK technique coverage as a security metric, and the paper demonstrates that the metric is unreliable in important ways. The present report's extension confirms and deepens that critique. ATT&CK remains the best common vocabulary the field has for describing adversary behaviour. The question raised by the original paper and the extension is whether that vocabulary should also be the metric, and the converging evidence is that it should not, at least not without substantial qualifiers about severity, labelling consistency, and the telemetry architecture of the system being measured.

References

- Australian Cyber Security Centre (2023). Strategies to Mitigate Cyber Security Incidents: the Essential Eight. Australian Signals Directorate.
- Australian Government (2018). Security of Critical Infrastructure Act 2018 (SOCI Act). Department of Home Affairs.
- Hutchins, E. M., Cloppert, M. J., & Amin, R. M. (2011). Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains. *Leading Issues in Information Warfare & Security Research*, 1, 80.
- International Organization for Standardization (2022). ISO/IEC 27001:2022 Information Security Management Systems: Requirements. ISO.
- Karantzas, G., & Patsakis, C. (2021). An Empirical Assessment of Endpoint Detection and Response Systems against Advanced Persistent Threats Attack Vectors. *Journal of Cybersecurity and Privacy*, 1(3), 387–421.
- Microsoft Security Response Center (2024). Midnight Blizzard: Guidance for Responders on Nation-State Attack. Microsoft Threat Intelligence.
- Microsoft Threat Intelligence Center (2022). MicrosoftSentinel.csv. Public Feeds, MITRE ATT&CK mappings. github.com/microsoft/mstic/blob/master/PublicFeeds/MITREATT%26CK/MicrosoftSentinel.csv
- MITRE Corporation (2022). ATT&CK Framework: Enterprise Version 11. attack.mitre.org
- National Institute of Standards and Technology (2024). Cybersecurity Framework 2.0 (NIST CSF). NIST.
- Pols, P. (2021). The Unified Kill Chain: Designing a Unified Kill Chain for Analyzing, Comparing and Defending against Cyber Attacks. Cyber Security Academy. unifiedkillchain.com
- Roy, S., Panaousis, E., Noakes, C., Laszka, A., Panda, S., & Loukas, G. (2023). SoK: The MITRE ATT&CK Framework in Research and Practice. *arXiv:2304.07411*.
- Vermeer, M., van Eeten, M., & Gañán, C. (2022). Ruling the Rules: Quantifying the Evolution of Rulesets, Alerts and Incidents in Network Intrusion Detection. In *Proceedings of the 17th ACM ASIA Conference on Computer and Communications Security (ASIA CCS '22)*, pp. 799–813.
- Virkud, A., Inam, M. A., Riddle, A., Liu, J., Wang, G., & Bates, A. (2024). How does Endpoint Detection use the MITRE ATT&CK Framework? *Proceedings of USENIX Security Symposium 2024*. github.com/avirkud/endpoint-detection-mitreattack

Appendix A: Reproduction Log

The following table summarises the twenty-seven discrete events recorded during the reproduction of Virkud et al.'s artefact. Each event is classified as a Difficulty (something the artefact did not document and the reproducer had to discover), a Workaround (a documented fix applied), or a Verification (a positive confirmation that an analysis reproduced as claimed).

#	Type	Event	Resolution / Outcome
1	Difficulty	Python version mismatch: artefact requires 3.8.10, host is 3.11.9	Proceeded with 3.11.9 (3.8 is EOL). Documented as version-drift exposure.
2	Difficulty	Carbon Black ruleset not in artefact (licensing)	Limited reproduction to Splunk/Elastic/Sigma. Documented as W17.
3	Difficulty	RQ2 has no shippable code (qualitative method)	RQ2 evaluated but not re-conducted. Noted in Section 4.3.
4	Difficulty	requirements.txt contains Linux-only wheels (nvidia-*, triton, pexpect, ptyprocess)	Curated minimal install (9 packages). Documented in Section 4.4.
5	Difficulty	PyTorch / KeyBERT stack unnecessary; pre-computed outputs shipped	Skipped KeyBERT cells; used pre-computed CSV. Reduced install footprint by ~3 GB.
6	Difficulty	No plotting code in RQ1 notebook; only DataFrames	Reproduced tables; plots remain a future-work item.
7	Difficulty	RQ3 dual-path execution (KeyBERT pipeline + pre-computed CSV)	Used pre-computed path. Saved >2 hours of GPU-bound execution.
8	Difficulty	Authors developed in WSL2, not native Windows	Native Windows reproduction is genuinely novel; documented all workarounds.
9	Difficulty	Major version drift: NumPy 1.24 → 2.4, pandas 2.0 → 3.0, scipy 1.10 → 1.17	Documented; all downstream errors traced to these.
10	Difficulty	NLTK 3.8.2+ requires punkt_tab in addition to punkt	Added punkt_tab to pre-emptive downloads.
11	Workaround	np.NaN removed in NumPy 2.0	Replaced with np.nan in parse_threat_column() in both notebooks.
12	Workaround	DataFrame.applymap deprecated in pandas 2.1	Replaced .applymap(len) with .map(len).

#	Type	Event	Resolution / Outcome
1 3	Verification	Splunk rule count	Reproduced: 911 rules (matches paper Table 1).
1 4	Verification	Elastic rule count	Reproduced: 473 rules (matches paper Table 1).
1 5	Verification	Sigma rule count	Reproduced: 2,195 rules (matches paper Table 1).
1 6	Verification	Figure 1 underlying data (technique count per tactic)	Reproduced: all 14 tactics match exactly across Splunk, Elastic, Sigma.
1 7	Verification	Technique density (1 / 1–5 / >50 rules)	Reproduced: 19/57/4 (Splunk), 25/62/0 (Elastic), 26/67/17 (Sigma). All within paper-reported ranges.
1 8	Verification	Spearman ρ Splunk vs Elastic	Reproduced: $\rho = 0.6389$, $p = 2.69e-23$ (paper: 0.639).
1 9	Verification	Spearman ρ Splunk vs Sigma	Reproduced: $\rho = 0.7010$, $p = 1.47e-29$ (paper: 0.701).
2 0	Verification	Spearman ρ Elastic vs Sigma	Reproduced: $\rho = 0.7617$, $p = 1.82e-37$ (paper: 0.762).
2 1	Verification	Case Study 1: CVE-2021-4034 cross-vendor disagreement	Reproduced: Elastic e69 [T1574+T1068] vs Splunk s489 [T1068].
2 2	Verification	Case Study 2: Meterpreter named-pipe disagreement	Reproduced: Elastic e479 [T1134] vs Splunk s229 [T1059+T1059.003+T1543+T1543.003].
2 3	Verification	Case Study 3: FIN7 tactic disagreement (Exfiltration vs C2)	Reproduced: Splunk s324 → Exfiltration; Elastic FIN7 rules → C2.
2 4	Verification	Case Study 4: Within-Splunk PrintNightmare inconsistency	Reproduced: 6 Splunk rules with T1547; 1 Splunk rule (s687) with T1068.
2 5	Difficulty	combined_rules_annotated_entities.csv contains 291 entities (pre-filter), paper reports 191 (post-filter)	Documented as W16. Per-entity analyses verifiable; aggregate count not.
2 6	Verification	Sentinel adapter validates: 10,132 raw → 349 unique Analytics rules, 81 techniques, 41.4% v11 coverage	Sentinel slots into commercial range. Adapter produces Virkud-compatible DataFrame.
2 7	Verification	Pre-registered hypothesis confirmed	Sentinel cloud techniques 2–6× over-covered; host techniques 5–26×

#	Type	Event	Resolution / Outcome
			under-covered. Spearman $\rho = 0.39$ – 0.50 vs within-Virkud 0.64–0.76.

Of the twenty-seven events: ten are difficulties documented for future reproducers, two are workarounds applied to the artefact code, and fifteen are verifications of specific paper claims (all of which matched the paper to three decimal places of agreement).

Appendix B: Extension Code Listing

The Microsoft Sentinel extension is implemented as two Python modules and one Jupyter notebook. The full source is included in the submission directory under `extension/notebooks/`. The files and their roles are summarised below.

File	Role	LOC
<code>extension/notebooks/sentinel_adapter.py</code>	Loads Microsoft Sentinel CSV; applies filters (Analytics only, dedupe by DetectionId, drop null TechniqueId); aggregates platforms and tactics; applies parent-technique flattening; produces Virkud-compatible DataFrame with rule_index, mitre_attack_id, name, description, severity, platforms, source columns. Also provides analysis helpers: <code>technique_coverage_summary()</code> , <code>techniques_unique_to_sentinel()</code> , <code>test_prereg_hypothesis()</code> , <code>coverage_percent_per_technique()</code> .	~230
<code>extension/notebooks/virkud_loader.py</code>	Wraps the data-loading logic from Virkud et al.'s RQ1 notebook into reusable functions. Includes the np.NaN-to-np.nan patch documented in Section 4.4. Exports <code>load_splunk()</code> , <code>load_elastic()</code> , <code>load_sigma()</code> , <code>load_techniques()</code> , <code>load_all_virkud()</code> .	~110
<code>extension/notebooks/sentinel_rq1_analysis.ipynb</code>	Clean analysis notebook. Cells: (1) imports; (2) load all 5 rulesets; (3) coverage summary; (4) Sentinel-unique vs Sentinel-missing techniques; (5) pre-registered hypothesis test; (6) Spearman rank correlations (both Sentinel-vs-others and within-Virkud sanity); (7) save outputs to <code>extension/outputs/</code> .	~120
<code>extension/outputs/coverage_summary.csv</code>	Section 5.3.1 Table 5.1 source.	n/a
<code>extension/outputs/hypothesis_test.csv</code>	Section 5.3.2 Table 5.2 source.	n/a
<code>extension/outputs/sentinel_unique_techniques.txt</code>	Section 5.3.2 unique-technique discussion source.	n/a

All analysis is deterministic: re-running the notebook on the same Sentinel CSV produces identical outputs to those reported in Section 5.3 of this report.